

Information Security Policy

2752676 Ontario Inc. (operating as Frugavo)

3546 Wyman Cres, Ottawa ON K1V 0Z1, Canada

Document version 1.0 · Effective May 2026 · Owner: Nabil Achache, Founder

1. Purpose and Scope

This policy defines how 2752676 Ontario Inc. (the "Company", operating as Frugavo) protects the confidentiality, integrity, and availability of the consumer financial data it processes through the Frugavo service. It applies to all systems, personnel, and third-party services involved in storing or transmitting Plaid-sourced transaction data, Stripe billing data, and Clerk identity data.

The Company currently has one operator (the founder) and no additional employees or contractors. Where this policy references "personnel" it refers to the founder; the policy is designed to scale as the team grows.

2. Roles and Responsibilities

Security accountability sits with the Founder, who serves as the de facto Chief Information Security Officer. Responsibilities include:

- Reviewing and updating this policy quarterly.
- Approving all third-party service integrations before they touch consumer data.
- Maintaining the production credentials inventory and rotating secrets at least annually.
- Responding to security incidents within the timelines stated in Section 10.
- Acting as the privacy contact for data-subject-rights requests.

Contact for security matters: security@frugavo.com.

3. Information Classification

All data the Company holds is classified into one of three tiers:

Tier	Examples	Handling
Restricted	Plaid access tokens, Stripe webhook secrets, AES master keys	Encrypted at rest, never logged, MFA-gated access
Confidential	User transaction history, detected subscriptions, billing records	Encrypted at rest, RLS-protected, server-side access only
Internal	Aggregated usage metrics, deploy logs, error stack traces	Restricted to founder; redacted of PII before review

4. Access Control

4.1 Principle of Least Privilege

Production access to Supabase, Stripe, Plaid, Clerk, Netlify, Upstash, Resend, and the GitHub repository is limited to the Founder. Role-based access controls (RBAC) are enforced by each provider's native permission model. There are no shared accounts. When the team grows, every new operator will be onboarded with scoped permissions matching their role; no operator will receive production-credential access by default.

4.2 Access Review

Because the Company has a single operator, access reviews are effectively continuous. As the team grows, a quarterly review of all production credentials and provider IAM roles will be instituted, with revocation enforced within five business days of any role change or departure.

5. Authentication

5.1 Consumer Authentication

End users authenticate to Frugavo via Clerk (clerk.com). Clerk enforces password complexity rules and supports multi-factor authentication (SMS, authenticator app, passkeys). MFA is available to all users at sign-up. Bot Protection is enabled on the production Clerk instance.

5.2 Administrative Authentication

All third-party administrative consoles used by the Company (Supabase, Stripe, Plaid, Clerk, Netlify, GitHub, AWS console, Upstash, Resend) require multi-factor authentication on the Founder's account. MFA is enforced via authenticator app and, where supported, hardware-backed passkeys.

6. Cryptography

6.1 Data in Transit

All consumer-facing traffic is served over HTTPS with TLS 1.3 (TLS 1.2 as the minimum fallback) enforced by Netlify's edge. Server-to-server traffic between Frugavo and Plaid, Stripe, Supabase, Upstash, Clerk, Resend, and Anthropic uses TLS over the public internet exclusively. HTTP requests are redirected to HTTPS at the edge with HSTS enabled.

6.2 Data at Rest

Supabase Postgres encrypts all data at rest using AES-256 at the storage layer (managed by AWS RDS). Plaid access tokens receive an additional application-layer encryption envelope using AES-256-GCM with a 256-bit key (TOKEN_ENCRYPTION_KEY) stored only in Netlify's environment-variable secret store. Loss of the application key would prevent decryption of stored Plaid tokens but would not expose user transaction data, which is encrypted independently at the Supabase storage layer.

6.3 Key Management

Application secrets are stored exclusively in Netlify's environment-variable secret store. Secrets are never committed to the source repository, never written to logs, and never shared via email or chat. Secret rotation is performed at least annually, and immediately following any suspected exposure.

7. Network and Infrastructure Security

The Frugavo application is deployed on Netlify (SOC 2 Type II), with the database hosted on Supabase (SOC 2 Type II) in the AWS us-east-1 region. Caching and rate-limiting are provided by Upstash Redis (SOC 2). The Company does not operate any self-managed servers, virtual machines, or network appliances. All infrastructure is fully managed by the listed vendors, each of which provides DDoS protection, automated patching, and intrusion detection at the platform level.

Row Level Security (RLS) is enabled on every Supabase table containing per-user data. The default RLS posture is deny-all; all application access is performed via a service-role key that is restricted to server-side runtimes and never exposed to the browser. The anonymous public key is not used by any code path in production.

8. Vulnerability and Patch Management

Software dependencies are tracked through GitHub Dependabot, which opens automated pull requests when CVEs are published against any direct or transitive npm dependency. Critical vulnerabilities are patched within seven days; high vulnerabilities within thirty days; medium and below at the next scheduled deploy. Platform-level patching of operating systems and runtimes is the responsibility of the underlying vendors (Netlify, Supabase, Upstash), each of which performs this continuously.

9. Logging and Monitoring

Application-level events are logged through Netlify Functions logs and surfaced to Sentry for error aggregation. All authentication events are logged by Clerk; all billing events are logged by Stripe; all bank-connection events are logged by Plaid. A custom /api/health endpoint exposes liveness plus per-service status for use by external uptime monitors. Logs are retained for at least 30 days at each provider.

10. Incident Response

On detection of a suspected security incident, the Founder will:

- Within 1 hour: Contain the incident by rotating affected credentials and revoking compromised sessions.
- Within 24 hours: Notify Plaid and other affected third-party data partners using their published security channels.
- Within 72 hours: Notify affected users by email if personal data was confirmed exposed, in accordance with PIPEDA and applicable U.S. state breach-notification laws.
- Within 7 days: Produce a written post-incident report covering root cause, scope, remediation, and preventive measures.

11. Data Retention and Deletion

User data is retained for as long as the user maintains an active account. On account deletion (initiated by the user through Settings → Delete account or by support request to privacy@frugavo.com), the application calls POST /api/account/delete, which:

- Cancels any active Stripe subscription immediately, without proration.
- Calls Plaid /item/remove on every connected Item to revoke the access token.
- Hard-deletes every row across all 18 per-user tables in Supabase, including transactions, scan snapshots, billing mirrors, and audit trails.
- Removes the user's record from app_users last, completing the cascade.

Deletion is immediate; there is no soft-delete or grace period. Provider-level backups (e.g. Supabase point-in-time recovery) retain a snapshot of deleted data for up to seven days before being purged, in accordance with each provider's retention guarantees. The Company will accommodate explicit data-subject-rights requests under PIPEDA, GDPR, and CCPA within thirty days.

12. Third-Party Risk Management

Before integrating any vendor with access to consumer financial data, the Founder reviews the vendor's published security documentation (SOC 2 / ISO 27001 / equivalent attestation), data-processing agreement, and breach-notification commitments. Current critical vendors and their attestations:

Vendor	Role	Attestation
Plaid Inc.	Bank-connection / transactions	SOC 2 Type II, ISO 27001
Supabase	Database, auth backing	SOC 2 Type II, HIPAA
Netlify	Application hosting + CDN	SOC 2 Type II, ISO 27001
Stripe	Payment processing	PCI DSS Level 1, SOC 2 Type II
Clerk	Identity / authentication	SOC 2 Type II
Upstash	Cache / rate limiting	SOC 2 Type II
Resend	Transactional email	SOC 2 Type II
Anthropic	ML classification API	SOC 2 Type II

13. Privacy and Consent

User consent for data collection is obtained at three layers: (a) acceptance of the Terms of Service and Privacy Policy at account creation; (b) the Plaid Link flow itself, in which Plaid presents its own consent screen before any bank credentials are entered; and (c) granular controls in the user dashboard for notification preferences and account deletion. The privacy policy is published at <https://frugavo.com/privacy> and is reviewed at the same cadence as this document.

The Company does not sell, license, or share consumer transaction data with third parties. No data is used for advertising, lead-gen, or analytics outside of the in-app subscription-detection purpose.

14. Business Continuity and Disaster Recovery

The application's runtime is fully managed by Netlify, which operates a globally distributed edge network with automatic failover. Database backups are provided by Supabase via automated daily snapshots and point-in-time recovery within a seven-day window. In the event of a vendor outage exceeding four hours, the Founder will (a) post status to **frugavo.com**, (b) extend any trial-conversion or billing-grace windows that would otherwise expire during the outage, and (c) coordinate restoration with the affected vendor. RTO target: 24 hours. RPO target: 24 hours.

15. Acceptable Use

Personnel will not: (a) export consumer financial data to personal devices or unsanctioned third-party tools; (b) reuse production credentials across personal accounts; (c) discuss specific user data outside of the context of a support ticket or incident response; (d) install development tooling that transmits source code to third-party LLM services without first reviewing the vendor's data-handling policy.

16. Policy Review and Versioning

This policy is reviewed at least quarterly and updated whenever: a new third-party vendor is integrated, a significant architectural change is made, a security incident occurs, or applicable law materially changes. Each update increments the document version recorded in the header. Material changes are communicated to Plaid (and any other partner with a security review on file) within thirty days.

Approval

Approved by Nabil Achache, Founder and Security Officer

Entity 2752676 Ontario Inc.

Effective date May 25, 2026

Next scheduled review August 25, 2026

Document version 1.0



Signature · Nabil Achache · Founder

This document is the property of 2752676 Ontario Inc. Distribution is permitted to regulated counterparties (payment processors, banking data aggregators, and similar) as part of their standard security-review process. Redistribution beyond that purpose is prohibited.